

OFFSEC

PENTEST REPORT



8

LISTA DE FIGURAS

Figura 1 – Passos do Relatório7



SUMÁRIO

PENTEST REPORT	4
1 CRIANDO RELATÓRIOS	4
1.1 O que seu relatório precisa conter?	4
2 RELATÓRIO DE PENTEST	6
2.1 Estágios do desenvolvimento do Relatório	7
2.2 Coleta de informações	9
2.3 Rascunho	10
2.4 Revisão	10
3 FORMATO DO RELATÓRIO	10
3.1 Lista de conteúdo	11
3.2 Sumário executivo	11
3.3 Metodologia	13
3.4 Detalhamento	13
3.5 Apêndices	15
REFERÊNCIAS	16

PENTEST REPORT

1 CRIANDO RELATÓRIOS

Na fase anterior, nós concluímos os testes de penetração contratados pelo nosso cliente, e agora será necessário analisar os dados coletados e criar Relatórios com base nesses dados.

1.1 O que seu relatório precisa conter?

Seus relatórios precisam incluir informações sobre os dados coletados e estratégias recomendadas para atenuar as vulnerabilidades que identificou. Você também deve criar uma estratégia para lidar com o relatório, incluindo como ele é apresentado ao cliente, como é armazenado e sua disposição.

Além disso, precisará realizar quaisquer atividades de entrega pós-Relatório identificadas na declaração de trabalho, como tarefas de limpeza ou ações de acompanhamento. Com isso, nosso objetivo será.

- Analisar a saída ou os dados da ferramenta relacionados a um pentest.
- Recomendar estratégias de mitigação para vulnerabilidades descobertas.
- Usar as práticas recomendadas para a elaboração e a manipulação de Relatórios.
- Realizar atividades pós-entrega de relatórios.

Coleta de dados do pentest

Ao realizar o teste de penetração, você coletará uma grande quantidade de informações altamente confidenciais. Você precisa garantir que os dados sejam tratados adequadamente para que essas informações não caiam nas mãos erradas. Os endereços, mapas de rede, detalhes de segurança e as vulnerabilidades desses e de outros fatores proporcionariam fácil acesso à rede para um hacker.

Outro conjunto de dados que você deveria ter reunido é um registro de todas as atividades que você executou na rede, sistemas e ambiente. Isso ajudará você e o cliente a identificar as atividades executadas como parte de seus testes e as de um invasor real. Isso pode incluir itens como:

- Acesso indevido a áreas protegidas por credenciais.
- Aplicações web comprometidas.
- Ataques bem-sucedidos de engenharia social.
- Ataques que bem-sucedidos via rede.
- Ataques onde foi possível a realização de “pivoteamento”.
- Dados e/ou credenciais vazados.
- Sites internos (ex.: Intranet) comprometidos.
- Evasões bem-sucedidas a mecanismos de detecção de intrusão.

Lembre-se de que, durante o pentest, você categorizou os ativos do seu cliente para determinar a melhor forma de abordar a exploração. Você deve executar uma tarefa semelhante após compilar os resultados do teste.

Você pode categorizar seus dados da maneira que fizer sentido para você e o cliente. Pode ser benéfico categorizar suas descobertas em termos dos tipos de ativos com os quais elas se relacionam. Por exemplo, uma injeção SQL bem-sucedida pode ser classificada como um problema de software. Você também pode criar subcategorias, como problemas de aplicativos da web, como uma subcategoria de problemas de software.

Além disso, você desejará criar categorias com base no nível de gravidade das vulnerabilidades e fraquezas descobertas durante o teste. Os itens que afetam a maioria das pessoas, sistemas e dados, provavelmente, são itens de alta prioridade, enquanto aqueles que afetam poucas pessoas, sistemas ou dados são categorizados em um nível inferior.

Dependendo das necessidades do cliente, do setor e de outros fatores, você e o cliente precisam trabalhar juntos para priorizar os resultados dos seus testes. A abordagem mais comum é categorizar itens com termos como níveis de gravidade crítico, alto, médio e baixo. Você pode optar por aplicar uma escala numérica aos itens, como 1 para itens de baixa gravidade e 10 para os itens mais críticos.

Esteja ciente de que, em alguns casos, o que parece ser o item mais urgente pode não ser tão urgente com base na necessidade da empresa de cumprir com as organizações de padrões, na existência de hardware mais antigo ou especializado ou em outros fatores. Por exemplo, a conformidade com o PCI DSS pode ser a maior prioridade para a organização, mesmo se houver outras vulnerabilidades marcadas como uma gravidade mais alta.

Dependendo do setor do cliente, pode ser necessário considerar itens como PII e PHI, além de outros fatores, como acessibilidade de rede, acessibilidade de construção e similares.

Tudo isso pode influenciar a maneira como você prioriza os resultados do pentest. Por fim, é importante entender que há mais nuances na priorização de resultados do que apenas rotular algo como severidade "média" porque o CVSS diz isso.

2 RELATÓRIO DE PENTEST

Muitos dos recursos de teste de penetração atualmente disponíveis não possuem metodologia e abordagem de redação de relatórios, o que leva a uma lacuna muito grande no ciclo de testes de penetração.

Relatório, em sua definição, é uma declaração dos resultados de uma investigação ou de qualquer assunto sobre o qual informações definidas são necessárias. Neste capítulo, iremos verificar o passo a passo da construção de um relatório de Pentest, usando exemplos abaixo do que deve conter em cada item.

Um teste de penetração é inútil sem algo tangível para dar a um cliente ou diretor-executivo. Um relatório deve detalhar o resultado do teste e, se você estiver fazendo recomendações, documente as recomendações para proteger quaisquer

sistemas de alto risco. A elaboração de Relatórios é uma parte crucial para qualquer prestador de serviços, especialmente em provedores de serviço / consultoria de TI.

No teste, o resultado é um relatório que mostra os serviços prestados, a metodologia adotada, os resultados dos testes e as recomendações. O leitor-alvo do relatório de testes de penetração irá variar. O resumo executivo pode ser lido pela gerência sênior e os detalhes técnicos serão lidos pela TI e / ou pessoas responsáveis pela Segurança da Informação.

Este capítulo começa com uma abordagem convencional para desenvolver um Relatório de testes de penetração a partir da coleta de informações, redigindo o primeiro Relatório. Como mostrado na figura abaixo, um relatório de teste de penetração tem os seguintes estágios: planejamento do relatório, coleta de informações, escrita do primeiro rascunho e revisão e finalização.

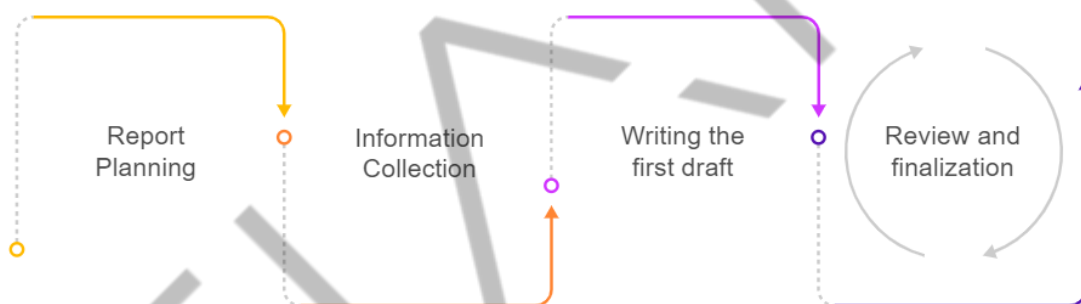


Figura 1 – Passos do Relatório
Fonte: Adaptado por Fiap (2020)

2.1 Estágios do desenvolvimento do Relatório

Objetivo do Relatório

Os objetivos do Relatório ajudam o leitor a focar nos principais pontos da penetração do teste e do Relatório. Uma vez que os objetivos estejam claros, tanto o leitor quanto o pentester saberão exatamente qual é o objetivo do projeto.

Tempo

O Pentester precisa mencionar exatamente o tempo de teste por vários motivos. Isso pode incluir:

- Na infraestrutura de missão crítica, a organização pode precisar certificar-se de que algumas pessoas-chave de TI estão disponíveis durante o teste, caso alguma coisa dê errada, por exemplo: falha do servidor.
- Na rápida mudança da infraestrutura de TI, as mudanças precisam ser congeladas no escopo de teste de penetração, durante sua ocorrência, para se certificar de que o teste avaliará exatamente a TI atual (o escopo do teste de penetração).
- Apesar de não haver 100% de segurança, o Relatório mostrará os riscos no âmbito do teste de penetração durante esse período de tempo. Quaisquer riscos após esse tempo podem surgir, devido a algumas mudanças na infraestrutura de TI, modificando na configuração.

Público-alvo

Os relatórios de testes de penetração geralmente têm vários públicos-alvo / grupos para alcançar. Por isso, um relatório terá frequentemente uma estrutura hierárquica para níveis de detalhes. Ao projetar o formulário e o estilo do relatório, o seguinte público-alvo/características devem ser considerados:

- Necessidade do relatório (ou seja, planejamento operacional, recurso, alocação e aprovação).
- Posição na organização.
- Conhecimento do tópico do relatório (ou seja, propósito).
- Responsabilidade ou autoridade para tomar decisões com base no Relatório.
- Dados demográficos pessoais (por exemplo, idade, alianças e atitudes).

Os leitores do relatório incluem o gerente da segurança da informação, diretor de segurança, gerente de tecnologia da informação e equipes técnicas.

Classificação do Relatório

Como o Relatório de Teste de Penetração possui informações confidenciais, como IP de servidores, endereços e suas informações, algumas informações sobre aplicativos, vulnerabilidades, ameaças, explorações e outras devem ser consideradas em todos os níveis elevados de confidencialidade, por exemplo: TOP SECRET. A classificação do relatório deve basear-se na política de classificação de informações da organização-alvo.

Distribuição de relatórios

O número de cópias do Relatório, seu formato (cópia impressa, cópia eletrônica) e o procedimento de entrega devem ser cuidadosamente implementados para controlar a distribuição do Relatório. E certifique-se de só chegar à pessoa certa, no momento certo, com base na necessidade.

O tipo de entrega do Relatório, o número de cópias e a distribuição do Relatório devem ser abordados no âmbito do trabalho. As cópias impressas podem ser controladas imprimindo o número de cópias anexadas com seu número e o nome do destinatário.

2.2 Coleta de informações

Devido à natureza do Pentest e utilizando mais de uma maneira, ferramentas, computadores etc., o Pentester precisa ter certeza de que coletou todas as informações em todas as etapas, sistema utilizado e ferramentas.

Isso facilitará a redação do Relatório e fará com que informações de que ele precisa disponíveis em cada etapa, passando para a próxima, usando informações e analisá-lo na atividade de teste de penetração ou durante o Relatório escrito. No caso de um teste de penetração ser realizado por uma equipe, um serviço centralizado e um local seguro precisam existir para compartilhar todas as informações.

A coleta de informações durante os estágios / etapas de teste de penetração é um passo muito importante para poder escrever o Relatório. Isso inclui resultados de varredura, vulnerabilidade da avaliação, instantâneos das descobertas e *exploits* (se houver) etc. O Pentester precisa considerar a coleta de informações em todas as etapas que ele realiza durante o teste.

2.3 Rascunho

Comece a esboçar um rascunho preliminar usando todas as informações relevantes reunidas. Nesta fase, é altamente recomendável não se preocupar com revisão e edição. Normalmente, 60% do tempo de escrita do Relatório será escrevendo o rascunho.

Pode ser útil usar um símbolo como "#" ou adicionar realces para marcar o local onde você precisa revisar e voltar mais tarde para editar um parágrafo. Elimine o símbolo quando a edição estiver completa.

2.4 Revisão

O rascunho precisa ser revisado para ser aprimorado. A revisão por pares é altamente recomendável para ter uma segunda opinião. Caso o teste de penetração tenha sido conduzido por uma equipe, todos os membros da equipe precisam revisá-lo e/ou editá-lo.

O conhecimento do sistema-alvo ajudará a rever o Relatório de forma colaborativa. Isso levará a resultados muito melhores. A revisão do Relatório depende também do procedimento da organização e da maneira que ela lida com o serviço.

3 FORMATO DO RELATÓRIO

Esta seção descreve o formato do Relatório de testes de penetração e explica por que precisamos de cada subseção.

Formato da página

No planejamento do Relatório, é necessário definir o design da página que será desenvolvida, incluindo as fontes utilizadas, formatações de cabeçalho e rodapé, além dos estilos de cores.

Capa

Mostrará o nome, versão do Relatório, data e nome do autor / prestador de serviços. A capa também pode incluir número de série e nome da organização de destino.

Propriedades do documento

Em uma pequena tabela, mostrará o título do documento, versão, autor, nome dos Pentester, nome das pessoas que revisaram o Relatório, nome da pessoa que aprovou e a classificação do documento.

Controle de versão

Acompanhará as alterações do Relatório, gravando a descrição da alteração, a versão do Relatório, data da alteração e autor da alteração.

3.1 Lista de conteúdo

Tabela de conteúdo

Listará todas as seções do Relatório em uma sequência com a página números. Normalmente, para Relatórios com menos de 5 páginas, uma página de conteúdo não é necessária. Se o Relatório incluir alguns apêndices, os títulos deles devem ser listados, mas não numerados na página.

Lista de ilustrações

Se houver tabelas ou gráficos incluídos no Relatório, liste-os nesta seção com números de página.

3.2 Sumário executivo

O sumário executivo resume o conteúdo do Relatório em um pequeno parágrafo contendo uma declaração das tarefas realizadas, metodologia, achados e recomendações de alto nível para os executivos que verão onde as descobertas/questões de alto nível precisam ser levantadas e as soluções recomendadas. Esta seção, normalmente, é escrita depois de escrever o Relatório.

Escopo de trabalho

Identifica claramente o escopo do projeto, endereços IP que foram testados, o tipo de teste de penetração executado e quaisquer outras informações que afetam o tempo e o orçamento do projeto.

Detalhes do projeto

Forneça os detalhes sobre a exploração das vulnerabilidades encontradas, contendo sua explicação técnica e grau de criticidade, para que a organização entenda os riscos relacionados aos alvos e o que eles necessitarão realizar a fim de mitigar esses riscos.

O objetivo do teste de penetração precisa ser vinculado a objetivos de segurança da informação que deverão estar ligados a objetivos da organização. Se o teste de penetração fizer parte do projeto de conformidade, o Relatório precisa mencionar esse requisito.

Consideração

Caso haja algumas considerações antes ou durante o teste, os pressupostos precisam ser claramente mostrados no Relatório. Fornecer a suposição ajudará as reuniões sobre o Relatório, para entender por que os testes de penetração seguiram uma direção específica.

Timeline

Indicará as datas de início e término do teste de penetração e fornecerá ao público-alvo do Relatório informações sobre:

1. Duração do teste.
2. Os riscos do endereço IP testado, do ponto de vista do teste, durante esse período apenas.
3. O pentester não possui quaisquer responsabilidades se algum risco ocorrer após esse período, devido a algumas alterações nos sistemas de destino.

Resumo das conclusões

De relance, veja o número de riscos descobertos com base em prioridades.

Resumo da recomendação

Com base na análise de riscos e no alto nível de descoberta, a alta recomendação de nível para a organização-alvo precisa ser descrita.

3.3 Metodologia

Esta seção fornece as informações necessárias sobre como o teste de penetração foi conduzido. Quais passos foram seguidos para coletar as informações, analisá-las, metodologia de classificação de risco usada para calcular o risco para cada item de vulnerabilidade e pode conter as ferramentas usadas pelo pentester para cada estágio.

3.4 Detalhamento

Esta seção fornece informações detalhadas para cada descoberta. Apresentar os resultados da maneira mais simples possível. Para cada descoberta, descreva o nível de ameaça, a vulnerabilidade da avaliação, a análise da questão e o impacto sobre o ativo de informação (o endereço IP), se o agente de ameaça foi capaz de explorar a vulnerabilidade, a classificação de risco e a recomendação.

Cada um desses elementos será informado nos próximos parágrafos. Há um certo número de maneiras pelas quais os resultados podem ser apresentados. Aqui estão algumas:

- Tabelas.
- Gráficos.
- Torre ou gráficos de barras.
- Diagramas.

Vulnerabilidades

Para cada item de vulnerabilidade, uma descrição clara deve ser mostrada sobre sua origem, seu impacto e as probabilidades da vulnerabilidade para serem exploradas. O Relatório deve explicar a origem da vulnerabilidade e a causa-raiz do problema não é o sintoma dele. Isso irá mitigar a vulnerabilidade persistência.

Impacto

O Relatório deve explicar o impacto da exploração da vulnerabilidade pelo agente de ameaça.

Probabilidade

Probabilidade de uma vulnerabilidade potencial exercida dentro do construto do ambiente de ameaça associado. O Relatório deve indicar essa probabilidade sendo explorada pela fonte de ameaça (por exemplo, um hacker).

O pentester pode pensar na probabilidade como uma combinação de facilidade de acesso, nível de acesso, dificuldade de descobrir a vulnerabilidade e explorá-la, e o valor do recurso para a organização de destino.

Avaliação de risco

Com base na classificação de risco e no ativo-alvo, o pentester deve fornecer uma recomendação aceitável com alternativas. Por exemplo, fraco para protocolos de autenticação sendo usados para validar contas para acessar um cliente de banco de dados por meio do aplicativo ASP Web, o pentester pode fornecer mais opção para mitigar o risco, como:

1. Implementar infraestrutura de chave pública (PKI), fornecendo certificado a todos os usuários do banco de dados, e requerer autenticação baseada em certificado no *front-end*.
2. Importar o banco de dados de contas para o Active Directory e implementar autenticação por meio de SSL no site. Essa solução exigirá o design e a implementação do Active Directory.
3. Continuar a usar o protocolo de autenticação personalizado atual, que é altamente suscetível a ataques de falsificação ou man-in-the-middle.

O pentester também pode indicar controles com base na ISO / IEC 27001: 2005 que ajudarão a minimizar o risco descoberto.

Referências

É importante dar detalhes precisos de todo o trabalho de outros autores que forem referidos no Relatório. Detalhes devem incluir:

- Nome do autor e iniciais.
- Data da publicação.
- Título do livro, papel ou revista.

- Publisher.
- Local de publicação.
- Números de página.
- Detalhes do volume do diário no qual o artigo apareceu.

As referências devem ser listadas em ordem alfabética dos nomes dos autores. Certifique-se de que suas referências sejam precisas e abrangentes.

3.5 Apêndices

Um apêndice contém informações adicionais relacionadas ao Relatório, entretanto, que não são essenciais para as principais conclusões. Isso pode ser consultado se o leitor desejar, mas o Relatório não deve depender disso. Essas informações podem incluir o resultado da varredura, resultados da avaliação de vulnerabilidade ou outras informações que podem ser úteis para o leitor.

Glossário

Definindo os termos técnicos.

REFERÊNCIAS

KENNEDY, D.; O'GORMAN, J.; KEARNS D. **Metasploit**: The Penetration Tester's Guide. San Francisco, California: No Starch Press, 2011.

WEIDMAN, G. **Penetration Testing**: A Hands-On Introduction to Hacking. San Francisco, California: No Starch Press, 2014.

EMANIP